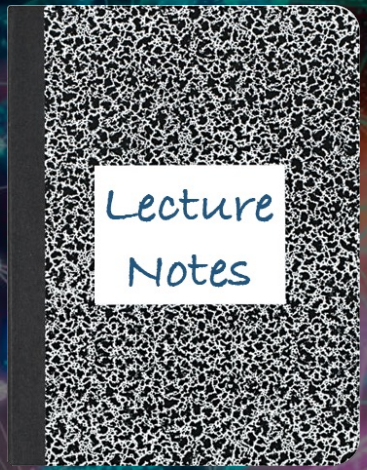
CS 419: Computer Security

Week 1: Part 1

Foundations of Computer Security



Paul Krzyzanowski

© 2026 Paul Krzyzanowski. No part of this content may be reproduced or reposted in whole or in part in any manner without the permission of the copyright owner.

Security as a Problem of Trust

Computer security:

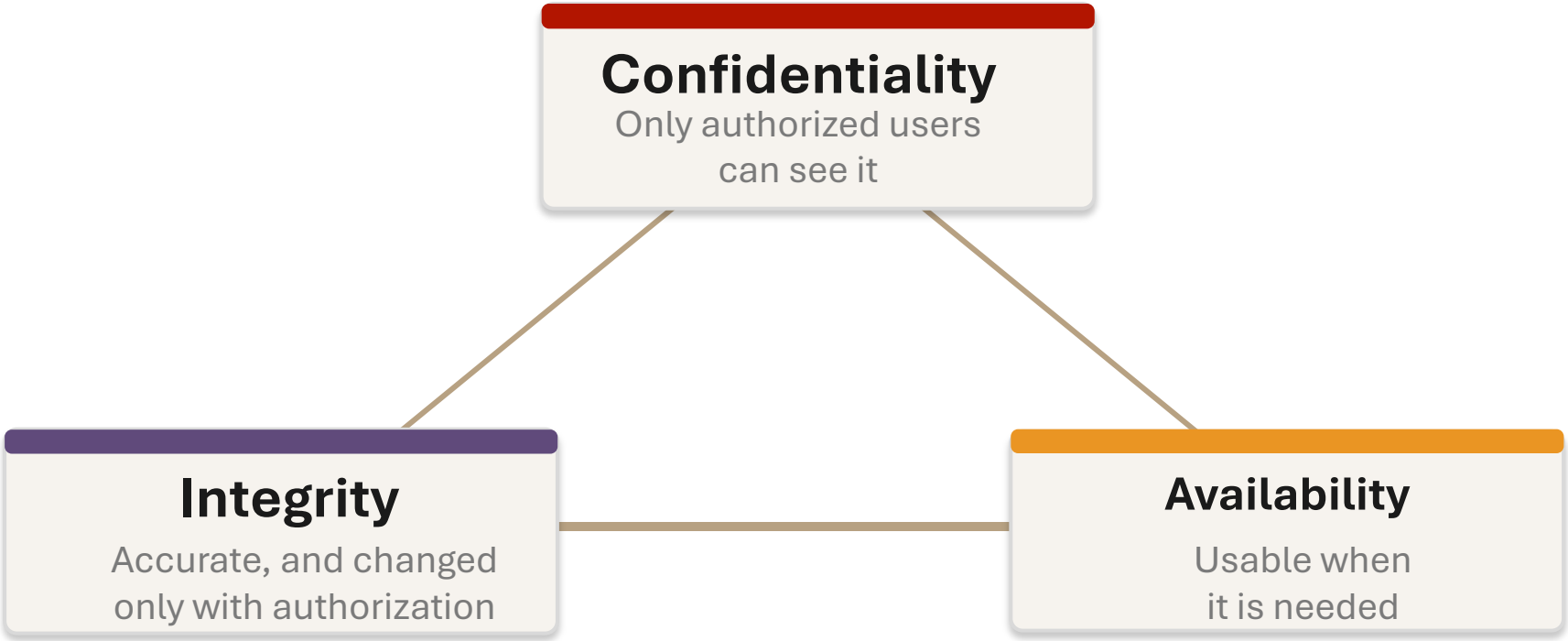
Protect computers, software, and data from
unauthorized access, modification, destruction, or disruption

Cybersecurity:

Includes networks, online services, and infrastructure

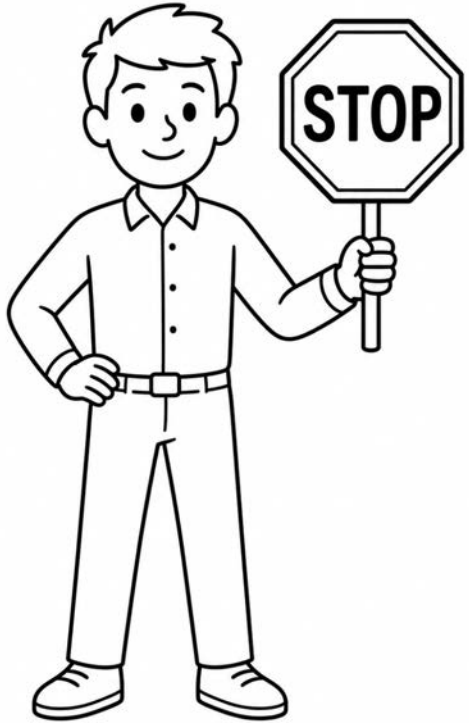
We'll ignore the distinction

The CIA* Triad



**No relationship to the Central Intelligence Agency*

Confidentiality



Confidentiality

Confidentiality: Allow only authorized users to access data & resources

– Applies to stored data & network data

- This has been the traditional focus of computer security
- Confidentiality is provided with **access controls** and/or **encryption**

Data confidentiality:

> "The property that information is not made available or disclosed to unauthorized individuals, entities, or processes [i.e., to any unauthorized system entity]."
>
> – *RFC 4949, Internet Security Glossary*

Confidentiality Fail: ClarityCheck (August 2026)

ClarityCheck, a people search tool, promised that the uploaded images are "private and secure"

- The site had over 9 million images publicly exposed – about 450 GB
- A second misconfiguration exposed email addresses and phone numbers
- Data was stored in an unprotected Amazon S3 service

- If proper **access control mechanisms** were used, unauthorized people wouldn't be able to get to the data
- If the data was **encrypted**, it would have been useless even if exposed

Reverse-Lookup Service Exposed Millions of Photos of People's Faces

WIRED

The people-search tool ClarityCheck says its reverse image search service is "private and secure"—but it left a database containing more than 9 million image files exposed.

Lily Hay Newman & Mat Burgess • August 19, 2023

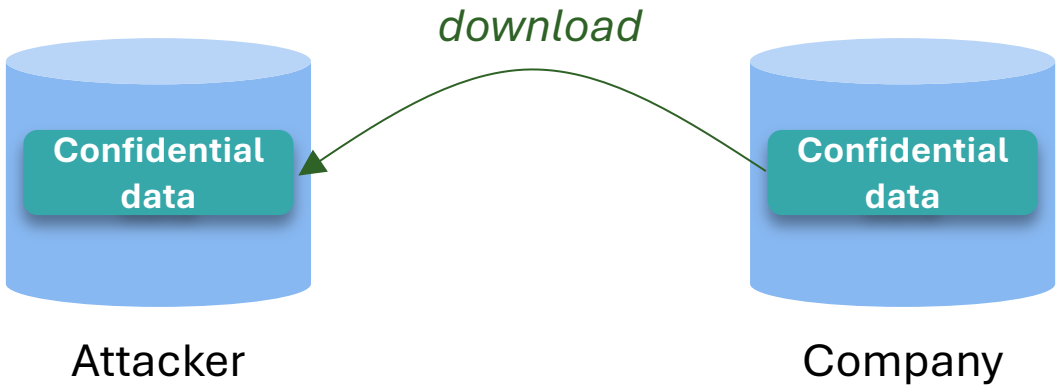
When someone uploads a photo to the people-search tool ClarityCheck, the website has a clear message: "Your reverse image search is private and secure." New research, though, shows that the website left more than 9 million image files, including photographs of people's faces, publicly exposed. And a second misconfiguration publicly exposed people's email addresses and phone numbers.

Overall, according to findings from independent security researcher Jeremiah Fowler, the exposed ClarityCheck database contained roughly 450 GB of images, including what appeared to be profile images, screenshots, and other photographs of adults, teenagers, and children. All of the images were stored in an unsecured Amazon S3 bucket, with files in folders named "faces" and "profiles," which could be accessed by anyone online through a URL included in the company's publicly available website code.

https://www.wired.com/story/reverse-lookup-service-exposed-millions-of-photos-of-peoples-faces/

Exfiltration

Exfiltration:
Unauthorized copying of data to an external location controlled by the attacker



Why steal data?

- **Espionage:** strategy, schedules, employees, and intellectual property

  Example: Salt Typhoon telecom espionage, 2019-2026. Chinese hacking group infiltrated telecom providers in the U.S. and 20+ other countries. They gain unauthorized access to call data, surveillance requests, and private communications. The breach enabled long-term intelligence collection on political figures. The campaign was revealed publicly in November 2024.

- **Obtaining credentials**: stolen login/password data may be used for other accounts

  Example: Shai-Hulud npm attack, August 2026. Attackers compromised 400+ popular npm packages and inserted a *preinstall* script. When the infected package was installed, the script searched the machine for GitHub and npm tokens, AWS/Azure/GCP logins, SSH keys, Kubernetes secrets, etc. and exfiltrated them to attacker-controlled servers or GitHub repositories.

- **Extortion**: threaten disclosure or destruction of data if not paid

  Example: Canvas attack, April-May 2026. The ShinyHunters group breached the Canvas LMS and exfiltrated student and faculty data from thousands of educational institutions. Instead of encrypting systems, the attackers threatened to publicly release the stolen data unless a ransom was paid, even displaying the extortion demand on Canvas login pages.

- **Impersonation:** masquerade as that user for social engineering

  Example: Coinbase breach, 2025. Attackers bribed support employees to exfiltrate customer records. They then used the stolen personal and account information to impersonate Coinbase support, convincing customers that their accounts were compromised and tricking them into transferring cryptocurrency.

Some Recent Major Data Breaches

Chinese surveillance database (2025)	~4 billion records (exposed data)
Ticketmaster / Snowflake (2024)	~560 million records
Change Healthcare (2024)	192.7 million people
DemandScience / Pure Incubation (2024)	121.8 million people
AT&T (2024)	~110 million customers
MOVEit / Cl0p (2023)	~96 million people
PowerSchool (2024–25)	~62.4M students + 9.5M educators
McDonald's McHire (2025)	64 million applicant records

Confidentiality – Privacy – Secrecy – Anonymity

Privacy

- Limit what information can be shared with others
- Control others' use of information about you
- Freedom from intrusion

The right of an entity (normally a person), acting in its own behalf, to determine the degree to which it will interact with its environment, including the degree to which the entity is willing to share its personal information with others.

See: HIPAA, personal information, Privacy Act of 1974
RFC 4949, Internet Security Glossary

Privacy is a reason for confidentiality

Anonymity: conceal the individual's identity – e.g., anonymous surveys
Secrecy: hide the existence of information – e.g., classified projects

cybernews

The Mother of All Breaches (MOAB)

January 2024:
12 TB, 26 billion records

An indexed compilation of records from breaches and privately-sold databases

https://cybernews.com/security/billions-passwords-credentials-leaked-mother-of-all-breaches/

BRANDS WITH 100M+ LEAKED RECORDS

BRAND NAME	RECORDS LEAKED
Tencent	1.5B
Weibo	504M
MySpace	360M
Twitter	281M
Wattpad	271M
NetEase	261M
Deezer	258M
LinkedIn	251M
AdultFriendFinder	220M
Zynga	217M
Luxottica	206M
Evite	179M
Zing	164M
Adobe	153M
MyFitnessPal	151M
Canva	143M
JD.com	142M
Badoo	127M
VK	101M
Youku	100M

cybernews

Related Terms: Privacy – Secrecy – Anonymity

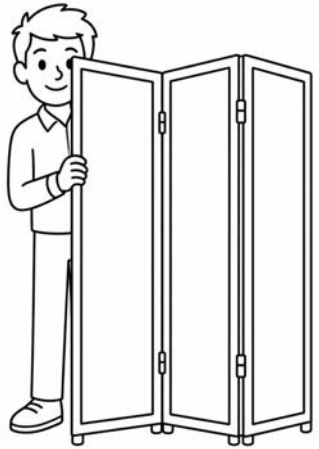
Confidentiality: hiding/restricting access to information

Privacy: control how others use information about you

Anonymity: conceal the individual's identity

Secrecy: hide the existence of information

Privacy is a reason for confidentiality







Privacy Fail: Nobody Hacked Anything

- GM enrolled drivers in *OnStar Smart Driver* at the dealership
  - Often without the driver's knowledge, through a confusing sign-up flow
- The car reported its precise location as often as every three seconds
  - Plus hard braking, hard acceleration, speeding, and late-night driving
- GM sold it to consumer reporting agencies, who sold it to insurers

Premiums went up. Coverage was denied



Anonymity Fail: Databroker Files

Anonymity: hiding a person's identity even when their actions are visible

Databroker Files (netzpolitik.org, BR, Le Monde, and others), November 2025

- Journalists asked commercial location-data brokers for free preview samples
  - Records only had Mobile Advertising IDs – no names
  - Two samples covering Belgium held 278 million location records
  - 9,600 pints from 543 devices inside NATO headquarters
    5,800 from 756 devices at the European Parliament
  - Overnight location ⇒ home address; weekday location ⇒ office
- Reporters identified the home addresses of five EU employees, including a senior Commission official and a member-state diplomat

Simply removing names is not anonymizing

Privacy is increasingly harder to attain

- **"Free" services**
  - Facebook, Google, X, LinkedIn, Instagram, TikTok, …
  - Information collection, tracking web sessions
- **More data is online and widely accessible**
  - No need to go to town halls to get real estate transactions
- **Phone companies know every place you go** (thanks to cell towers)
- **Networks, big data analytics, and AI:**
  - It's easy to get & correlate data:
    credit card spending, travel, jobs, marriages/divorces, kids, cars, …

> "If you are not paying for it, you're not the customer; you're the product being sold"
>
> *– blue_beetle (Andrew Lewis), 2010*

UNESCO Recommendation on the Ethics of AI (2021)

"AI systems should not be used for social scoring or mass surveillance purposes"

Secrecy Fail: NSA secretly collecting the phone records

Secrecy: intentionally concealing information or even its existence

- 2013: Edward Snowden, a contractor at the NSA, copied a large set of classified documents and gave them to journalists
  - Largest disclosure of classified intelligence in U.S. history
- The first Snowden document released was a four-page court order
- It ordered Verizon to hand over all call records, every day
  - Metadata only. No call content, no subscriber names

The protected asset
was the existence of the program

Secrecy Fail: A Seven Kilometer Run

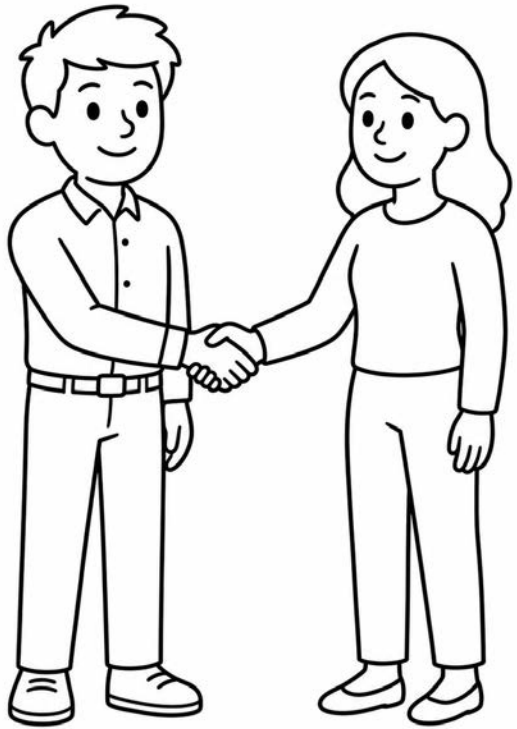
March 13, 2026, 10:35 in the morning

- A French naval officer runs seven kilometers in 35 minutes, in loops
  - On the flight deck of the nuclear aircraft carrier Charles de Gaulle
- His smartwatch syncs to Strava.
  - The profile is public by default
- Reporters at *Le Monde* discover it
- The trace gives the carrier's position: Eastern Mediterranean, ~100 km off the Turkish coast, mid-deployment



The ship's location was secret.
A newspaper figured it out from a jogging app.

Integrity



Integrity

- **The trustworthiness of the data or resources**
- **Preventing unauthorized changes to the data or resources**

Data integrity

Property that data has not been modified or destroyed
in an unauthorized or accidental manner

Origin integrity & Recipient integrity

Identification & authentication

System integrity (Functional integrity)

The ability of a system to perform its intended function,
free from deliberate or inadvertent manipulation

Integrity is often more important than confidentiality!

Attacks on Integrity

Data modifications usually don't make the news

- Companies are usually not legally required to disclose them
  (GDPR requires only the disclosure of breaches containing personal information)

- Email spoofing, caller ID spoofing
- Network traffic redirection (we'll study these mechanisms later)
- Poisoning AI models
  - University of Maryland 2020 experiment on the Google Auto ML image recognition platform
    0.1% of poisoned (modified) data caused the algorithm to identify a frog as an airplane in 80% of cases

https://www.tributech.io/blog/cybersecurity-threat-data-tampering

Authenticity vs. Integrity

Authenticity:

evidence that a person, system, or message is what it claims to be

- Authenticity covers entities as well as data
  - Person logging in, server presenting a certificate, a voice on a phone
- Origin integrity is authenticity applied to data.
  Authenticity also covers the people and systems making the claim.



Availability



Availability

Availability: being able to use the data or resources

- **Property of a system being accessible and capable of working to the required performance specifications**

Turning off a computer provides confidentiality & integrity but hurts availability

Denial of Service (DoS) attacks target availability

Denial of Service Attack: Canonica (April 30, 2026)

- Distributed Denial of Service (DDoS) attack
  - Timed to the Ubuntu 26.04 LTS release
- Multiple services were down or severely degraded:
  - ubuntu.com, download mirrors, Launchpad, Snap Store, and single sign-on
- No package updates, ISO downloads, Launchpad logins for several days

Nothing was stolen – the attack was on availability

Amazon Outage Took Citi Bike Offline At Height Of Rush Hour

gothamist

Security isn't always about adversaries attacking … sometimes it's services failing

Jake Offenhartz • December 22, 2021

Citi Bike riders were left stranded on Wednesday after an outage at an Amazon data center knocked out service to the bike-share system during the height of the morning rush hour.

The disruption began shortly after 7:00 a.m., sparking complaints and confusion from monthly subscribers unable to unlock a bike. A spokesperson for Lyft, the Citi Bike parent company, said stations were beginning to come back online as of 9:20 a.m., though some riders continued to report issues.

Outside Bellevue Hospital in Manhattan on Wednesday morning, would-be commuters stood in front of a docking station fruitlessly trying to connect to the bikes with their phones.



https://gothamist.com/news/amazon-outage-took-citi-bike-offline-height-rush-hour

Thinking about security

Thinking about security

Security is not

- adding encryption
- … or using a 512-bit key instead of a 64-bit key
- … or changing passwords
- … or setting up a firewall

It is a systems issue

= Hardware + firmware + OS + app software + networking + people

= Processes & procedures, policies, detection, forensics

"Security is a chain: the weakest link breaks it"

– Bruce Schneier

Security is hard

Software is complex

- Windows 11: 60-100 million lines of code
- Google services comprise ~2 billion lines of code
- Linux distribution: over 200 million lines of code
  - Linux kernel: >40 million lines of code; ~87,000 files
  - 75,462 commits in 2025 from 5,637 different authors
  - 4.8 million lines changed in one year

Try to find the bugs … or keep up with the changes!

Systems are complex

- Lots of layers: microcode + firmware + OS + libraries + apps + devices
- Interaction with cloud services
- Third-party components
- Complex interaction models, concurrency
- All parts are not always under the control of one administrator

The human factor

- People make mistakes: coding, configuration, usage

Microsoft Patches a Record 570 Security Flaws

KrebsonSecurity
In-depth security news and investigation

July … 421 more patches in August 2026

Brian Krebs • July 14, 2026

Microsoft Corp. today released software updates to plug at least 570 security holes in its Windows operating systems and other software, almost triple the number of vulnerabilities the software giant fixed in its record-smashing Patch Tuesday release last month. Microsoft attributed the burgeoning patch counts to vulnerability discoveries aided by artificial intelligence.

Nearly 60 of the bugs quashed in July's Patch Tuesday earned a "critical" severity rating, meaning miscreants or malware could use them to seize remote control over a Windows device with little or no help from the user. Microsoft also addressed three zero-day flaws, including two that are already being exploited in the wild.

Two of the zero-day weaknesses allow an attacker to elevate their user rights on a Windows system, as do approximately 250 other elevation of privilege flaws fixed this month; they include CVE-2026-56155 — an Active Directory Federation Services bug — and CVE-2026-56164, a Microsoft Sharepoint vulnerability.
…
"The pace of vulnerability discovery is changing with advances in AI making it possible to find more issues, faster, across more code, with new mechanisms that can accelerate both discovery and analysis," Davuluri wrote.

https://krebsonsecurity.com/2026/07/microsoft-patches-a-record-570-security-flaws/

Defending is more difficult than attacking

The defender must cover every reachable path;
The attacker needs just one



That was where we left off on the September 1 lecture.

September 8 content follows.

Security Goals

Prevention: prevent attackers from violating the security policy

- Implement mechanisms that users cannot override
- *Example: ask for a password*

Detection: detect & report attacks

- Important when prevention fails
- Indicates & identifies weaknesses in prevention
- *Also useful for detecting attacks even if prevention is successful*

Recovery: restore systems and operations after the attack

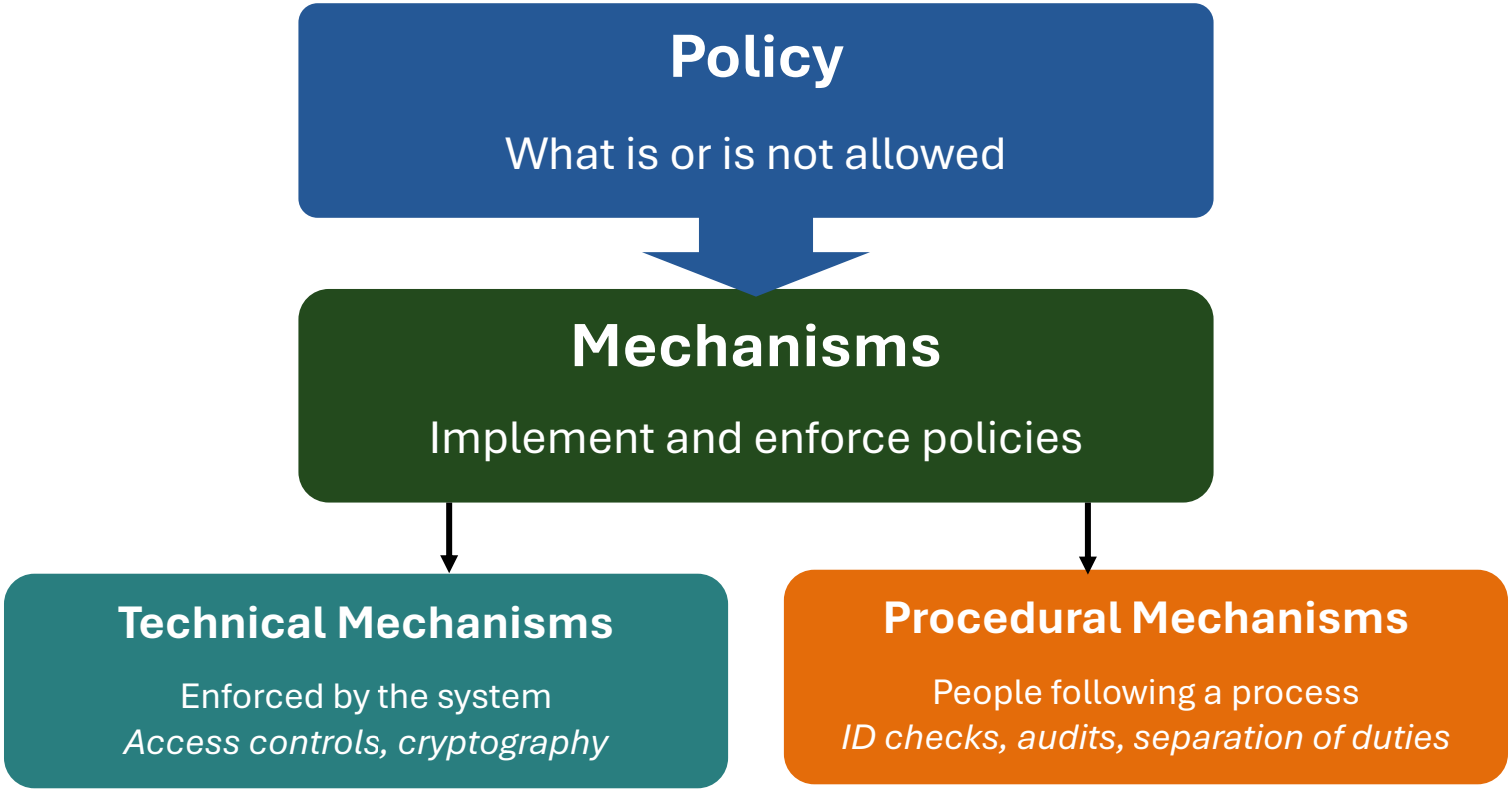
- **Forensics**: identify what happened so you can fix it
- *Example: restore from backups (but backups may be contaminated!)*

A Recovery Story: The Server In West Africa

- June 2017:
  NotPetya malware reaches Maersk through a Ukrainian tax software update
  - It destroys 49,000 laptops and 3,500 of 6,200 servers
  - It destroys the central employee and machine directory, and every replica
- One clean copy survives on a server in West Africa
  - A power cut had taken that server offline before the malware arrived
  - The link was too slow, so employees flew the disk to England



Policies & Mechanisms



Policies & Mechanisms

Policy: *what is or is not allowed*

- Can be expressed in natural language (“this is our security policy”)
- **Policy language** – the goal is to provide precision together with ease of understanding

Mechanisms: *implement and enforce policies*

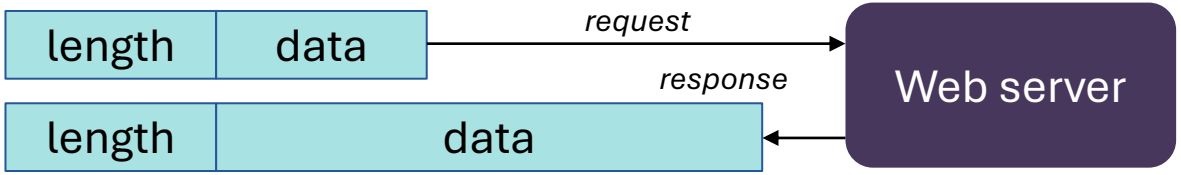
- E.g., password entry & authentication
- **Technical mechanisms**: access controls, cryptography, locked doors, …
- **Procedural mechanisms**: ID checks, audits, separation of duties, …

- *What mechanisms do we need to secure a system?*
- *What level of assurance is associated with them?*

Assumptions Can Open Doors to Attacks

Heartbleed, April 2014

- **OpenSSL heartbeat feature accepted a message length value without checking it**
  - A one-byte request could claim 64 KB, and get 64 KB of memory
  - That memory might hold passwords or private keys



- **Programmers made an assumption that the message length would be correct**
  - The software did what it was supposed to
  - There was ***no policy failure*** → no alert

The policy was sound

The mechanism did not enforce it

Nothing looked wrong

Security Engineering

Security Architecture ⇒ Design

- How do we put a secure system together?
- How do we identify potential weaknesses?

Security Engineering ⇒ Implementation

- Implement mechanisms & policy into a system

Combination of

1. **Policy** (rules)
2. **Mechanisms** (implementation)
3. **Assurance** (integrity of the mechanisms and policy)
4. **Incentives** (the human factor)

Security Engineering

Engineering means making compromises

- Understand tradeoffs
- Security vs.
  complexity, cost, performance, acceptability, usability
  - Is it cheaper to prevent an attack or recover?
  - Who pays & who gets punished?

Compromises: Cost-Benefit-Risk Decisions

A Medeco M4 Maxum deadbolt costs several hundred dollars.

It resists picking, bumping, and drilling for longer



Medeco 11C63 Maxum Commercial Double Cylinder Deadbolt, 6-Pinned, DL Keyway, Captive Key, M4 High Security

(No reviews yet) Write a Review

medeco ASSA ABLOY

Model: MED-11C63LT-26-DLN

~~$306.00~~

$290.91

A basic Kwikset deadbolt costs ~$20.

Most people buy this over the Medeco





Kwikset

Visit the Kwikset Store

Kwikset 660 Deadbolt Lock, Satin Nickel Round Exterior Keyed Front Entry Door, Single Cylinder Dead Bolt, with Microban Protection

4.4 ★★★★½ (377) | Search this page

2K+ bought in past month

$19.97 Price history

No defense is perfect

Cost vs. consequence

And who the attackers are

Risk analysis

Should we protect something?

- If so, how carefully?
- And how much should we spend?

Laws & customs

- Are any security measures illegal?
  - Example: types of encryption
- Are any measures unlikely to be used?
  - Examples: retina scans, urine tests
  - Conformance: balance security vs. effort

10. DISCLAIMER OF WARRANTY. The application is licensed "as is," "with all faults," and "as available." You bear the entire risk as to its quality, safety, comfort, and performance. Should it prove defective, you assume the entire cost of all necessary servicing or repair. The application publisher, on behalf of itself, Microsoft, wireless carriers over whose network the application is provided, and each of our respective affiliates, vendors, agents, and suppliers ("Covered Parties"), gives no express warranties, guarantees, or conditions in relation to the application.

Microsoft Services Agreement – July 30, 2025

Some risk mitigation is taking legal measures

Risk Analysis



What you must protect	What could cause harm	The weakness that lets it	The path it takes	What you add to reduce it	What is left over

Risk analysis is deciding which controls are worth their cost, not eliminating all risk.

Some risk always remains, and you decide to accept it

A Threat Model for a Grade System

A threat model is a walkthrough of what could go wrong with one system:

- **Asset**: grade records, their integrity and their confidentiality
- **Threat**: someone gains access and alters or discloses them
- **Vulnerability**: password only, and some users reuse passwords
- **Attack vector**: credential stuffing against the public login page
- **Security controls**: multi-factor authentication, rate limits, audit log
- **Residual risk**: a stolen session, a deceived agent, an insider

Four Responses to a Risk

1	**Mitigate**	Add controls that reduce the likelihood or impact
2	**Avoid**	Disable the activity/service that creates the risk
3	**Transfer**	Shift the risk to someone else: insurance, contracts, outsourcing, disclaimers
4	**Accept**	Understand the risk and choose to accept it

Trust in the system & software

Security Assumptions

The heart of all security rests on assumptions about:

- Type of security needed
- The environment where the system is deployed
- **Trusted** components & principals (users, other systems)

Example: *You need a key to open a locked door*

- You assume that the lock is a trusted component and is secure against lock-picking
- BUT … a skilled lock picker can open the lock

Your assumptions are wrong *IF*

- The key is available to unauthorized people (bad policy)
- The environment has a skilled, untrustworthy lock picker
  (bad mechanism: wrong assumption about the environment)
- The lock is trivial to pick (bad mechanism)

Your security needs

The environment

System & software components

Who the users are

Trust: Trustworthy components

Trustworthy components may have the capabilities to break security policies … but will not do so: they will follow the policy

Examples

- A *trustworthy* lock picker will not bypass security unless properly authorized
- A *trustworthy* CPU will correctly enforce memory protections and not allow a user to read regions of memory disallowed by the operating system
- A trustworthy operating system will not allow you to read or modify files to which you do not have access permissions

- **If a core component turns out to be *not trustworthy* then the security of the *entire system* may be at risk**
- **Example: a malicious boot loader can patch the code of the operating system, which can then run a malicious program or change the behavior of programs**

Assurance = our faith in the system

Assurance = our confidence that the system's operation, security controls, and policies work as intended and enforce security policies

Specifications	Statement (formal or informal) of the desired functioning of the system
Design	The components that will implement the specification
Implementation	• The creation of a system that satisfies the design • Difficult (impossible) to prove the correctness of the implementation of a complex system
Testing & auditing	• **Auditing** = inspecting the code for security-critical bugs • Because we usually cannot prove the correctness of a system, we rely on extensive testing to get that lucky feeling that it works – **Functional testing** to assess that the system works as desired – **Penetration testing** to assess that the system follows policy and is resilient to bad inputs, missing components, unexpected events, etc.

Trusted Computing Base (TCB)

TCB = All hardware & software of a computing system critical to its security

> "The totality of protection mechanisms within it, including hardware, firmware, and software, the combination of which is responsible for enforcing a computer security policy."
>
> – *Orange* Book
> *U.S. Department of Defense Trusted Computer System Evaluation Criteria (TCSEC)*

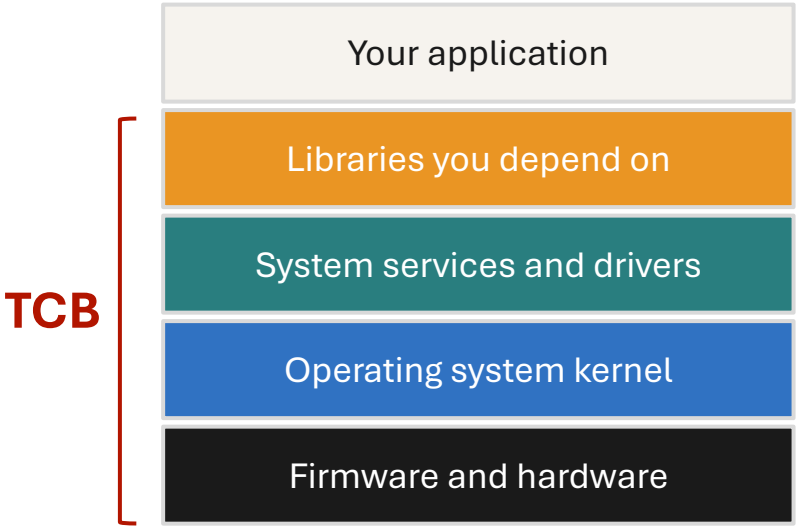
If the TCB is compromised, we can no longer guarantee the security of a system

Software that is part of the TCB must protect itself against tampering

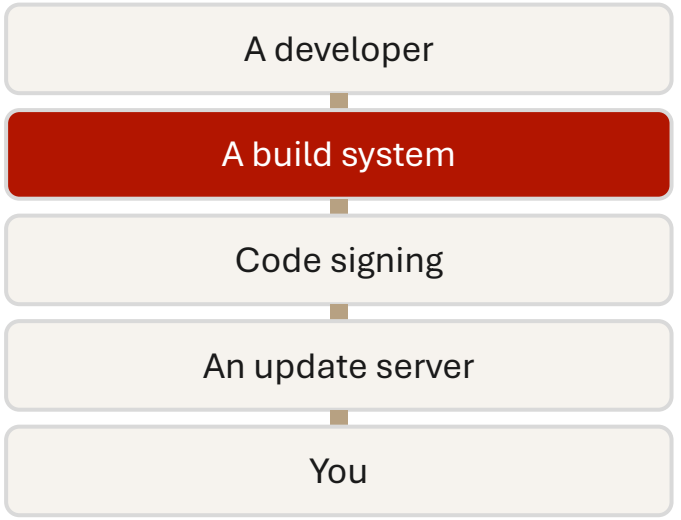
- Operating system memory protection is an example of this: an application may be compromised but the operating system is still intact and unaffected

Trusted Computing Base & The Supply Chain

The TCB: what must be correct



The supply chain: how it got here

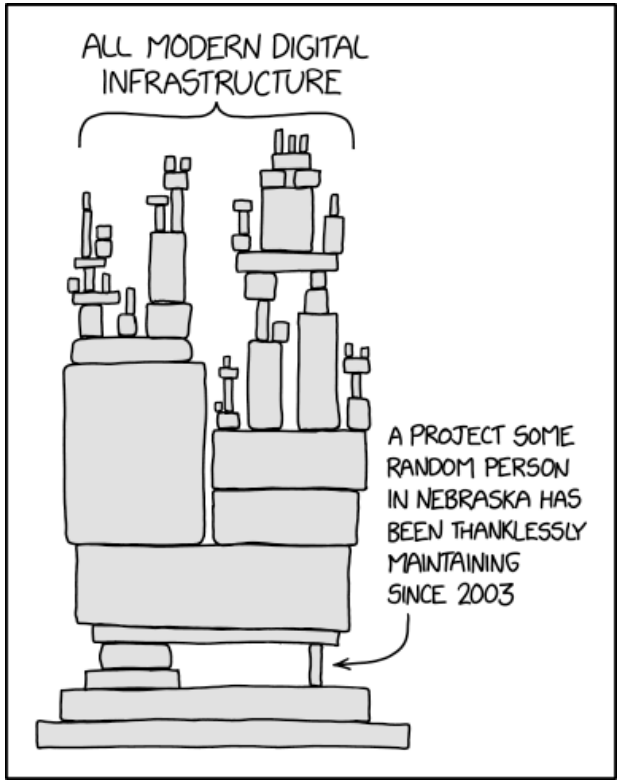


SolarWinds attack: the signature was valid. The build system was compromised.

A library you depend on is inside the TCB. The supply chain is how it got there.

Supply chain problem: assurance

- **Do you trust the hardware?**
- **Do you trust every piece of code that is required to run your infrastructure?**
- **Do you know where it comes from?**
- **How actively it's maintained?**
- **Whether it's been audited for vulnerabilities?**



https://xkcd.com/2347/

Supply Chain Attack: npm Packages

August 2026

An email impersonating npm is sent to package maintainers.

- A request to update multi-factor authentication ⇒ attacker got credentials
- The attacker published a new version of each package, **with an install-time script**

- Anybody who installed the package ran the script
  - The script scans the machine and build system for more credentials
  - If the victim publishes packages, it republishes them with the script
  - The cycle repeats from the next maintainer it reaches

- Over 1,300 package versions affected – 2 billion downloads a month
  - Most people affected had never chosen any of those packages
  - They were dependencies from other packages

Jan 2018 – Meltdown & Spectre

Intel chips do not have full memory protection when doing speculative execution

Vulnerability existed for 20 years!

- **Meltdown**
  - Allows processes to access kernel memory
- **Spectre**
  - Allows processes to steal data from the memory of other processes
- **Also affected ARM & AMD CPUs**



www.wired.com/story/critical-intel-flaw

Critical "Meltdown" and "Spectre" Flaws Break Basic Security for Intel, AMD, ARM Computers | WIRED

One of the most basic premises of computer security is isolation: If you run somebody else's sketchy code as an untrusted process on your machine, you should restrict it to its own tightly sealed playpen. Otherwise, it might peer into other processes, or snoop around the computer as a whole. So when a security flaw in computers' most deep-seated hardware puts a crack in those walls, as one newly discovered vulnerability in millions of processors has done, it breaks some of the most fundamental protections computers promise—and sends practically the entire industry scrambling.

Earlier this week, security researchers took note of a series of changes Linux and Windows developers began rolling out in beta updates to address a critical security flaw: A bug in Intel chips allows low-privilege processes to access memory in the computer's kernel, the machine's most privileged inner sanctum. Theoretical attacks that exploit that bug, based on quirks in features Intel has implemented for faster processing, could allow malicious software to spy deeply into other processes and data on the target computer or smartphone. And on multi-user machines, like the servers run by Google Cloud Services or Amazon Web Services, they could even allow hackers to break out of one user's process, and instead snoop on other processes running on the same shared server.

On Wednesday evening, a large team of researchers at Google's Project Zero, universities including the Graz University of Technology, the University of Pennsylvania, the University of Adelaide in Australia, and security companies including Cyberus and Rambus together released the full details of two attacks based on that flaw, which they call Meltdown and Spectre.

"These hardware bugs allow programs to steal data which [is] currently processed on the computer," reads a description of the attacks on a website the researchers created. "While programs are typically not permitted to read data from other programs, a malicious program can exploit Meltdown and Spectre to get hold of secrets stored in the memory of other running programs."

Rowhammer

- **Hardware-based attack discovered by Google Project Zero in 2014**
  - Exploits a weakness in modern DRAM chips.
- **Vulnerability**
  - Repeatedly accessing (or "hammering") a row of memory cells at high speeds can cause electrical interference that flips the bits in adjacent rows of memory cells
- **Attackers were able to**
  - **Corrupt sensitive data**, potentially crashing applications or the OS
  - **Gain escalated privileges** by modifying data such as page tables in the OS
  - **Bypass security mechanisms** to execute malicious code
- **Affects multiple operating systems and platforms**

Rowhammer attack can backdoor AI models with one devastating bit flip

CSO

Security researchers have devised a technique to alter deep neural network outputs at the inference stage by changing model weights via row hammering in an attack dubbed ‘OneFlip.’

Lucian Constantin • August 25, 2025

team of researchers from George Mason University has developed a new method of using the well-known Rowhammer attack against physical computer memory to insert backdoors into full-precision AI models. Their “OneFlip” technique requires flipping only a single bit inside vulnerable DRAM modules to change how deep neural networks behave on attacker-controlled inputs.

“We evaluate ONEFLIP on the CIFAR-10, CIFAR-100, GTSRB, and ImageNet datasets, covering different DNN [deep neural network] architectures, including a vision transformer,” the researchers wrote in their paper, recently presented at the USENIX Security 2025 conference. “The results demonstrate that ONEFLIP achieves high attack success rates (up to 99.9%, with an average of 99.6%) while causing minimal degradation to benign accuracy (as low as 0.005%, averaging 0.06%). Moreover, ONEFLIP is resilient to backdoor defenses.”

https://www.csoonline.com/article/4044876/rowhammer-attack-can-backdoor-ai-models-with-one-devastating-bit-flip.html

4.5% of breaches now extend to fourth parties

Help Net Security • May 27, 2025

Security teams can no longer afford to treat third-party security as a compliance checkbox, according to SecurityScorecard. Traditional vendor risk assessments, conducted annually or quarterly, are too slow to detect active threats.

35.5% of all breaches in 2024 were third-party related, a 6.5% increase from 2023. This figure is likely conservative due to underreporting and misclassification. So while you're updating your firewall rules, somewhere in your supply chain a vendor might be inadvertently letting in the very attackers you've been working to keep out.

46.75% of third-party breaches involved technology products and services, a drop from last year's 75%, signaling a diversification of attack surfaces. File transfer software remained the top third-party breach enabler, with Cl0p exploiting vulnerabilities in Cleo software (CVE-2024-50623 and CVE-2024-55956) to launch large-scale attacks.

4.5% of breaches now extend to fourth parties, one breach triggers multiple organizational failures.

https://www.helpnetsecurity.com/2025/05/27/third-party-breaches-increase/

Supply chain attack hits Chrome extensions, could expose millions

Threat actor exploited phishing and OAuth abuse to inject malicious code

Connor Jones • Jan 22, 2025

Cybersecurity outfit Sekoia is warning Chrome users of a supply chain attack targeting browser extension developers that has potentially impacted hundreds of thousands of individuals already.

Dozens of Chrome extension developers have fallen victim to the attacks thus far, which aimed to lift API keys, session cookies, and other authentication tokens from websites such as ChatGPT and Facebook for Business.

Chrome support impersonation

The attacker targeted dev teams with phishing emails seemingly from Chrome Web Store Developer Support, mimicking official communication, according to Yusoff and Sekoia.

The sample email, which appears in the report, shows the warnings that extensions may be pulled from Chrome over fake rule violations, such as unnecessary details in the extension's description.

Victims were lured into clicking a link disguised as an explanation of Chrome Web Store policies. The link led to a legitimate Google Accounts page, where they were prompted to approve access for a malicious OAuth app. Once developers granted the app permission, the attacker gained everything needed to upload compromised versions of their extensions to the Chrome Web Store.

https://www.theregister.com/2025/01/22/supply_chain_attack_chrome_extension/

Log4J: severe vulnerability in a common 3rd party Java library

FEDERAL TRADE COMMISSION
PROTECTING AMERICA'S CONSUMERS

ABOUT THE FTC | NEWS & EVENTS | ENFORCEMENT | POLICY | TIPS & ADVICE | I WOULD LIKE TO...

Home » News & Events » Blogs » Tech@FTC » FTC warns companies to remediate Log4j security vulnerability

FTC warns companies to remediate Log4j security vulnerability

By: This blog is a collaboration between CTO and DPIP staff and the AI Strategy team | Jan 4, 2022 9:19AM

SHARE THIS PAGE

TAGS: Accountability | Data security | Patches

Log4j is a ubiquitous piece of software used to record activities in a wide range of systems found in consumer-facing products and services. Recently, a serious vulnerability in the popular Java logging package, Log4j (CVE-2021-44228) was disclosed, posing a severe risk to millions of consumer products to enterprise software and web applications. This vulnerability is being widely exploited by a growing set of attackers.

When vulnerabilities are discovered and exploited, it risks a loss or breach of personal information, financial loss, and other irreversible harms. The duty to take reasonable steps to mitigate known software vulnerabilities

Subscribe

Subscribe to Tech@FTC Blog updates

Upcoming FTC Tech Events

Currently we have no upcoming Tech events. Please check back soon.

Additional Information

Office of Technology Research & Investigation

https://www.ftc.gov/news-events/blogs/techftc/2022/01/ftc-warns-companies-remediate-log4j-security-vulnerability

XZ Utils – the almost disaster

XZ Utils: an attempt to add a backdoor to a common Linux library

- **XZ Utils: set of open-source software for compression and decompression**
- **Included with many Linux distributions & widely used**
- **Around 2021:**
  - A developer with the name Jia Tan started to make requests for bug fixes and improvements
  - Jia built trust and eventually got permission to commit and then be a release manager
  - Social engineering: Fake accounts created for sending lots of bug & feature requests pressured the original maintainer into adding Jia Tan as another maintainer
- **In 2023:**
  - After two years of fixing bugs, Jia Tan introduced a few changes to XZ. Among these changes was a sophisticated backdoor.
  - This would enable an attacker to run arbitrary commands on software that used XZ Utils, like ssh, the secure shell
  - It almost made it to every major Linus distribution
- **But in March 2024:**
  - A Microsoft employee, Andres Freund, discovered an unexpected 500 ms latency after doing an update
  - He traced it to this unexpected code in XZ Utils.

New UEFI vulnerabilities send firmware devs industry wide scrambling

The ability to attack the boot process

PixieFail is a huge deal for cloud and data centers. For the rest, less so.

ars technica

Dan Goodin • January 17, 2024

UEFI firmware from five of the leading suppliers contains vulnerabilities that allow attackers with a toehold in a user's network to infect connected devices with malware that runs at the firmware level.

The vulnerabilities, which collectively have been dubbed PixieFail by the researchers who discovered them, pose a threat mostly to public and private data centers and possibly other enterprise settings. People with even minimal access to such a network—say a paying customer, a low-level employee, or an attacker who has already gained limited entry—can exploit the vulnerabilities to infect connected devices with a malicious UEFI.

Short for Unified Extensible Firmware Interface, UEFI is the low-level and complex chain of firmware responsible for booting up virtually every modern computer. By installing malicious firmware that runs prior to the loading of a main OS, UEFI infections can't be detected or removed using standard endpoint protections. They also give unusually broad control of the infected device.

…

The implementation is incorporated into offerings from Arm Ltd., Insyde, AMI, Phoenix Technologies, and Microsoft.

https://arstechnica.com/security/2024/01/new-uefi-vulnerabilities-send-firmware-devs-across-an-entire-ecosystem-scrambling/

Malicious Chinese SDK In 1,200 iOS Apps With Billions Of Installs Causing ‘Major Privacy Concerns To Hundreds Of Millions Of Consumers’

Unknowingly bundling spyware into an app

John Koetsier • August 24, 2020

Forbes

A Chinese ad network named Mintegral is accused of spying on user activity and committing ad fraud in more than 1,200 apps with 300 million installs per month since July 2019. Mintegral is headquartered in Beijing, China, and is owned by another Chinese ad network, Mobvista, which has a head office in Guangzhou, China.

One of the apps, Helix Jump, has over 500 million total installs. Other popular apps that are impacted include Talking Tom, PicsArt, Subway Surfers and Gardenscapes.

All together, this likely impacts billions of total app installs on iPhone and iPad.

There’s no exact number on how many devices or iPhone users are impacted, but Snyk says this is a “major privacy concern to hundreds of millions of consumers.”

https://johnkoetsier.com/malicious-chinese-sdk-in-1200-ios-apps-with-billions-of-installs-causing-major-privacy-concerns-to-hundreds-of-millions-of-consumers/

The End